COMPLIANCE & SECURITY · CHECKLIST

Minimum Viable Security Posture Checklist

For founders and operators who need a credible, defensible security baseline without building an enterprise security program.

> **How to use this:** Work through each of the five domains and check off what's genuinely in place today. Anything unchecked is your near-term action list. If you build product with AI coding tools, complete the AI-built product section too.

Trust and Transparency

- [ ] We have a plain-language statement of how we protect customer data that we can share on request.
- [ ] We know which subprocessors or vendors touch customer data, and could list them if asked.
- [ ] We have a named person (even part-time) who owns security questions from customers.
- [ ] Our privacy policy and terms accurately reflect what we actually do, including any use of AI.
- [ ] We could answer 'how is our data protected' in under five minutes, in writing, today.

Access Control

- [ ] We can list everyone with access to production systems and customer data, and why they have it.
- [ ] Billing, admin and infrastructure systems use individual logins, not shared credentials.
- [ ] Multi-factor authentication is on for email, code repositories, cloud and billing. Admin accounts use phishing-resistant MFA (passkeys or security keys) where supported.
- [ ] Service accounts, API keys and tokens have a named owner, and none are shared between systems.
- [ ] Access is removed within 24 hours of someone leaving or changing roles.

Device and Endpoint Basics

- [ ] All company laptops and phones used for work are password-protected and encrypted.
- [ ] Lost or stolen devices can be remotely locked or wiped.
- [ ] Company data isn't routinely stored only on personal, unmanaged devices.
- [ ] Operating systems and applications are patched promptly and kept on supported versions.

AI and Automation

The fifth domain. Most small teams now use AI tools daily, and buyers have started asking about them.

- [ ] We have a short list of approved AI tools, and a rule for what data can go into them.
- [ ] Company AI tools are used on company accounts, not personal accounts, for any work involving customer or confidential data.

© 2026 Rev-IQ. Free to use and adapt.

- [ ] We know which AI tools and agents have been connected to email, drives, code or the CRM, and what they can access.
- [ ] Customer data is not used to train third-party models, and we can show the vendor terms that confirm it.
- [ ] We can tell a customer, in writing, where AI is used in our product and how its outputs are checked.

Documentation and Response

Where is our current list of who has access to what, and when was it last updated?

Where is our written process for onboarding and offboarding access?

Where is our written process for a suspected security incident, including who decides whether we must notify a regulator?

Who is the single point of contact for a customer's security or procurement question?

When did we last test restoring from a backup, and did it work?

If Your Product Is AI-Built

For teams writing a meaningful share of their code with AI assistants or app builders.

- [ ] Secrets and API keys are kept out of code and prompts, and the repository is scanned for exposed secrets.
- [ ] Dependencies suggested by AI tools are checked before they are added, and a dependency scanner runs on every build.
- [ ] A person reviews every change to authentication, authorisation, payments and data access, whoever or whatever wrote it.
- [ ] Default settings from AI app builders (open databases, public storage, permissive access rules) are reviewed before launch.
- [ ] We have run at least one external or automated security test against the live application.

© 2026 Rev-IQ. Free to use and adapt.

When a Certification Becomes Worth It

Certify when a specific buyer or market needs it, not before.

Trigger	What it usually points to
US enterprise buyers ask for an attestation report	SOC 2 Type I, then Type II
Enterprise, government or tender buyers in Australia, NZ, the UK or Europe ask for certification	ISO/IEC 27001
Buyers ask how you manage AI risk, or AI is central to what you sell	ISO/IEC 42001 (AI management system), often alongside 27001
You sell to Australian government or critical-infrastructure customers	ASD's cyber security frameworks, now ASD Essentials for enterprise IT
None of the above yet	Keep this baseline current and offer a short security overview instead

Baseline Status Summary

Domain	Current state (Strong / Partial / Missing)	Owner	Next action
Trust and Transparency			
Access Control			
Devices and Endpoints			
AI and Automation			
Documentation and Response			
AI-built product (if relevant)			

© 2026 Rev-IQ. Free to use and adapt.

Where This Maps

Framework or obligation	Where this resource lines up
ASD Essentials for enterprise IT	Identity, credential and access management; least privilege; regular and proven backups; vulnerability management; artificial intelligence accountability (governance and culture)
ISO/IEC 27001:2022 Annex A	5.15 to 5.18 access control and rights; 8.1 user endpoint devices; 8.8 technical vulnerabilities; 8.13 backup; 8.25 to 8.28 secure development
Australian Privacy Act, APP 11	Reasonable steps to protect personal information from misuse, loss and unauthorised access
NZ Privacy Act 2020, IPP 5 and UK GDPR Article 32	Reasonable security safeguards for personal information
Australia's Guidance for AI Adoption	Practice 1, decide who is accountable; practice 3, measure and manage risks

General guidance, not legal advice. References to standards show where this resource aligns; using it does not make an organisation compliant or certified. Check your specific obligations with a qualified adviser. Regulatory references checked October 2026.

© 2026 Rev-IQ. Free to use and adapt.